

UNIVERSIDADE DE MOGI DAS CRUZES
BACHARELADO EM SISTEMAS DE INFORMAÇÃO

RAFAEL GASTÃO TRAJANO CARLOS

CONECTA SAÚDE
Módulo de login seguro

Mogi das Cruzes

2026

RAFAEL GASTÃO TRAJANO CARLOS

CONECTA SAÚDE

Módulo de login seguro

Atividade prática individual de Login Seguro apresentada ao curso de Bacharelado em Sistemas de Informação da Universidade de Mogi das Cruzes.

Disciplina: [preencher].

Professor(a): [preencher].

Mogi das Cruzes

2026

SUMÁRIO

1 INTRODUÇÃO	3
2 ESTRUTURA E CONTROLE DE ACESSO	4
3 AUTENTICAÇÃO E SEGURANÇA	5
4 MONGODB ATLAS E EXECUÇÃO LOCAL	6
5 APRESENTAÇÃO E ADAPTAÇÃO AO PFC	7
6 VERIFICAÇÃO E VERSIONAMENTO	8
REFERÊNCIAS	9

1 INTRODUÇÃO

Este trabalho apresenta um módulo de login seguro desenvolvido como atividade individual com Java, Spring Boot, Thymeleaf e MongoDB. Seu objetivo é organizar o cadastro, a autenticação, o encerramento de sessão e a autorização de acesso, preservando uma estrutura que possa receber a identidade do projeto Conecta Saúde.

O Conecta Saúde tem como proposta a educação sobre saúde sexual e infecções sexualmente transmissíveis, com recursos educativos destinados a jovens e adolescentes. Seus públicos incluem alunos, professores e administradores. Nesta atividade, esse contexto orienta a futura associação dos perfis de acesso, sem incluir jogos, questionários ou conteúdos educativos no sistema de login.

A implementação do PFC consultada utiliza Node.js, Express e PostgreSQL. A atividade de login constitui um projeto independente, desenvolvido com as tecnologias solicitadas no enunciado. Não existe integração automática entre os bancos de dados ou os mecanismos de autenticação dos dois projetos.

O escopo implementado compreende cadastro com validação, login por e-mail e senha, logout e páginas restritas para três perfis. As áreas internas demonstram a autorização. O administrador pode atribuir o perfil Professor; edição e exclusão de contas não fazem parte deste módulo. O documento descreve a estrutura existente, a configuração necessária para o Atlas e as verificações que antecedem a entrega.

2 ESTRUTURA E CONTROLE DE ACESSO

O projeto utiliza Java 21 e Spring Boot 3.5.6, com dependências administradas pelo Maven. A classe `AplicacaoLoginSeguro` inicializa a aplicação. A organização em pacotes separa as responsabilidades de apresentação, segurança e persistência.

O pacote `web` contém `ControladorAutenticacao`, `ControladorArea` e `ControladorAdministrador`. O primeiro apresenta as telas públicas e recebe o cadastro; o segundo encaminha a navegação para o painel e as áreas protegidas. Os controladores selecionam as páginas Thymeleaf e delegam o cadastro ao serviço. `ControladorAdministrador` permite ao administrador atribuir o perfil Professor.

O pacote `user` reúne `Usuario`, `Perfil`, `FormularioCadastro`, `ServicoUsuario` e `RepositorioUsuario`. O formulário concentra as validações de entrada; o serviço normaliza os dados e gera o hash da senha; o repositório acessa a coleção de usuários no MongoDB. A entidade contém identificação, nome, e-mail, hash, perfis, situação da conta e data de criação.

O pacote `security` contém `ConfiguracaoSeguranca` e `ServicoDetalhesUsuario`. A configuração define as permissões das rotas, o formulário de autenticação e o logout. O serviço de detalhes consulta a conta pelo e-mail e converte os perfis em autoridades reconhecidas pelo Spring Security.

ALUNO acessa `/painel` e `/aluno/inicio`. PROFESSOR acessa `/painel` e `/professor/inicio`, sem acesso à área do aluno. ADMIN acessa essas páginas e `/admin/inicio`. Esses perfis correspondem a aluno, professor e administrador, seguindo os públicos do Conecta Saúde.

O cadastro público oferece a escolha entre Aluno e Professor e salva o perfil selecionado. O servidor rejeita ADMIN e valores não permitidos. O login pede apenas e-mail e senha. O primeiro ADMIN deve ser definido no banco por um responsável autorizado. Depois, a área administrativa permite tornar uma conta Professor. A pessoa promovida deve sair e entrar novamente. Um conversor mantém a leitura dos perfis antigos USER e EDITOR.

3 AUTENTICAÇÃO E SEGURANÇA

No cadastro, o servidor exige nome, e-mail válido e senha com 9 a 72 caracteres, incluindo pelo menos um número e um caractere especial. O nome é normalizado e o e-mail é convertido para letras minúsculas após a remoção de espaços nas extremidades. O serviço verifica a existência de outro cadastro com o mesmo e-mail.

A senha é processada por BCrypt com custo 12 antes de ser persistida. O banco recebe passwordHash, e não a senha original. Hash é uma transformação de mão única: a autenticação compara a senha informada com o hash armazenado por meio do componente de segurança.

No login, ServicoDetalhesUsuario recupera a conta e disponibiliza suas autoridades. O Spring Security verifica a senha e restringe o acesso às rotas. A configuração também considera enabled, que permite representar uma conta desabilitada no banco. Após autenticação bem-sucedida, o usuário é encaminhado para /painel.

A proteção CSRF permanece habilitada. O logout utiliza uma requisição POST, invalida a sessão e solicita a remoção do cookie LOGINSEGUROSESSION. A configuração prevê proteção contra fixação de sessão e limite de uma sessão, cujo comportamento deve ser validado em execução.

O cookie é configurado com HttpOnly e SameSite=Lax. O atributo Secure é controlado por variável de ambiente: no desenvolvimento HTTP local fica desativado; em publicação HTTPS deve ser ativado. A conexão TLS com Atlas protege o transporte dos dados, enquanto o hash protege a representação das senhas armazenadas.

Há pontos que exigem validação adicional: BCrypt limita a entrada em bytes, mas o formulário limita caracteres; senhas Unicode próximas ao limite precisam de tratamento específico. A consulta prévia de e-mail não elimina condições de concorrência. Deve-se garantir o índice único e tratar adequadamente sua eventual violação.

4 MONGODB ATLAS E EXECUÇÃO LOCAL

O arquivo `application.yml` define a conexão por `MONGODB_URI` e o banco por `MONGODB_DATABASE`. O arquivo `.env.example` apresenta um modelo sem credenciais reais. O Spring Boot não lê automaticamente esse arquivo; os valores devem ser fornecidos pelo terminal, pela IDE ou pelo arquivo privado `application-local.properties`.

Para conectar ao Atlas, é necessário criar o cluster, cadastrar um usuário de banco e autorizar o IP da máquina executora. Recomenda-se conceder ao usuário apenas as permissões necessárias no banco `login_seguro`. A URI `mongodb+srv` deve conter os dados do cluster e credenciais válidas, com codificação de URL nos caracteres especiais da senha (MongoDB, s.d.).

O projeto utiliza `users` para contas e configura `sessions` para sessões com duração de 30 minutos. A dependência `Spring Session MongoDB` permite substituir o armazenamento local de sessão. A autoconfiguração está disponível na versão do Spring Boot utilizada, mas a persistência efetiva deve ser confirmada na coleção do Atlas durante o teste de login.

A entidade declara índice único para e-mail, porém não há ativação explícita da criação automática de índices. O responsável deve verificar ou criar esse índice no Atlas antes da entrega. O README apresenta o comando correspondente e as observações sobre registros duplicados.

Para executar, instale JDK 21 e Maven, defina `MONGODB_URI` e `MONGODB_DATABASE` e execute `mvn spring-boot:run` na raiz do projeto. O endereço padrão é `http://localhost:8081`. Para gerar um pacote executável, utilize `mvn clean package` e execute o arquivo JAR gerado em `target`.

A variável `MONGODB_URI` é obrigatória e aponta para o Atlas. O arquivo privado `application-local.properties` pode fornecê-la e é carregado automaticamente. Por isso, abrir a aplicação não comprova a integração com Atlas. É necessário verificar o destino da conexão, o cadastro na coleção `users` e a criação e invalidação das sessões. Nunca envie credenciais reais ao GitHub.

5 APRESENTAÇÃO E ADAPTAÇÃO AO PFC

A interface é composta por templates Thymeleaf e uma folha de estilos separada. As telas de cadastro e login ficam em templates/auth; as áreas restritas ficam em templates/areas. O fragmento templates/fragments/layout.html centraliza elementos compartilhados, como cabeçalho e rodapé.

O arquivo static/css/app.css concentra a apresentação visual. Essa separação permite modificar cores, tipografia e componentes sem alterar a consulta de usuários ou as regras de autenticação. Os templates utilizam condições de autorização para apresentar links compatíveis com o perfil autenticado; a proteção efetiva continua sendo aplicada no servidor.

A interface utiliza a identidade do Conecta Saúde, com fundo azul-escuro, detalhes verdes e formulários centralizados. A rota inicial abre o login, com navegação entre Entrar e Cadastrar. As áreas internas apresentam Aluno, Professor e Administrador como nomes amigáveis dos perfis ALUNO, PROFESSOR e ADMIN.

A estrutura facilita customizações, mas ainda não implementa seleção dinâmica de temas por configuração. Uma evolução possível é centralizar nome, identidade visual e caminho da folha de estilo em propriedades da aplicação, mantendo intactos os módulos de segurança e cadastro.

O reaproveitamento no PFC deve considerar a diferença de tecnologias. A arquitetura e as decisões de controle de acesso podem servir de referência, mas o código Java e as coleções MongoDB não substituem diretamente os componentes Node.js e PostgreSQL. Funcionalidades educativas permanecem fora desta atividade.

6 VERIFICAÇÃO E VERSIONAMENTO

O roteiro de verificação deve começar pelo cadastro válido e pela conferência de que o banco contém um hash e o perfil escolhido, ALUNO ou PROFESSOR. Em seguida, devem ser testados campos inválidos, e-mail repetido, credenciais incorretas e tentativa de acesso ao painel sem autenticação.

Para autorização, uma conta ALUNO deve ter acesso negado às áreas de professor e administrador. Uma conta PROFESSOR deve acessar sua área, mas não as áreas do aluno e do administrador. Uma conta ADMIN deve acessar todas as áreas previstas. Esses testes devem usar requisições às rotas, além da inspeção dos menus.

Também é necessário verificar a sessão no Atlas, testar logout e expiração e confirmar a rejeição de operações POST sem token CSRF. O roteiro descreve critérios de aceitação; não constitui evidência de testes executados. A entrega não inclui arquivos de testes automatizados. A conexão com Atlas foi validada, incluindo cadastro, login, acesso à área do professor e encerramento da sessão.

A publicação deve ocorrer em repositório público próprio, separado do PFC. Para Gitflow, main representa as versões entregáveis; develop reúne a evolução; feature organiza mudanças; release prepara uma entrega; hotfix trata correções urgentes. O README apresenta uma sequência de comandos para iniciar esse processo.

Na pasta revisada não foi encontrado repositório Git inicializado. Portanto, Gitflow e publicação são etapas pendentes, não resultados já realizados. Antes do envio, devem ser revisados os arquivos versionados e excluídas credenciais, saídas temporárias e dados reais de teste.

A entrega documenta uma base de autenticação e autorização associável ao Conecta Saúde. Sua conclusão depende da verificação em ambiente configurado, do tratamento dos pontos técnicos registrados no README e da publicação do código. Se for exigido CRUD de usuários, esse requisito deverá ser esclarecido, pois não integra as telas atuais.

REFERÊNCIAS

MONGODB. Connect to an Atlas Cluster. [S. l.], [s. d.]. Disponível em: <https://www.mongodb.com/docs/atlas/connect-to-database-deployment/>. Acesso em: 6 out. 2026.

SPRING. Spring Security reference. [S. l.], [s. d.]. Disponível em: <https://docs.spring.io/spring-security/reference/>. Acesso em: 6 out. 2026.

SPRING. Spring Session MongoDB repositories. [S. l.], [s. d.]. Disponível em: <https://docs.spring.io/spring-session/reference/3.4/guides/boot-mongo.html>. Acesso em: 6 out. 2026.

THYMELEAF. Documentation. [S. l.], [s. d.]. Disponível em: <https://www.thymeleaf.org/documentation.html>. Acesso em: 6 out. 2026.

UNIVERSIDADE DE SÃO PAULO. Guia para elaboração de trabalhos de conclusão de curso convencional conforme a ABNT NBR 14724 de 2024. Bauru, 2026. Disponível em: https://sddarquivos.webhostusp.sti.usp.br/arquivos/Guia_TC_C_convencional_FOB-USP.html. Acesso em: 6 out. 2026.